

ПРАКТИЧЕСКАЯ РАБОТА № 15.1

Тема: Разработка технических решений по защите вычислительной сети на основе систем обнаружения и предупреждения вторжений (IDS/IPS), их развертывание в сети и настройка

Программное обеспечение:

1. К работе прилагаются образы виртуальных машин Xubuntu и Windows XP, а также ISO-образ с необходимым ПО https://drive.google.com/drive/folders/1_ZJdGXm32oIQg5y8goEhHAXV2qVhA576?usp=sharing

Вопросы для обсуждения:

1. Что означают аббревиатуры IDS и IPS?
2. В чём разница между системами обнаружения вторжений (IDS) и предотвращения вторжений (IPS)?
3. Какие существуют основные подходы к классификации сигнатур угроз в IDS/IPS?
4. Что такое сигнатура угрозы в контексте IDS/IPS?
5. Для чего предназначен демон Snort и как он относится к тематике IDS/IPS?
6. Назовите два основных режима работы демона Suricata.
7. Какая основная задача агента HIDS (Host-based Intrusion Detection System)?
8. Какие типы датчиков используются в системах сетевого обнаружения вторжений (NIDS)?
9. Что такое ложноположительное срабатывание в контексте IDS/IPS?
10. Назовите основное преимущество размещения датчика IDS рядом с пограничным маршрутизатором.

Цель: изучить технологию защиты вычислительной сети на основе систем обнаружения и предупреждения вторжений (IDS/IPS).

Основные теоретические сведения

В данной работе будут установлены и настроены две системы обнаружения вторжений (COB, IDS) Suricata и OSSEC, а также система аналитики на основе стека Elasticsearch, Logstash и Kibana (ELK) для просмотра и анализа отчетов указанных COB.

С помощью виртуальной сети будет проведено сканирование портов и атака на веб-сервер, продемонстрирована работа системы предотвращения вторжений (СПВ, IPS). Также будет проведена настройка и демонстрация работы агента OSSEC на платформе Windows.

К работе прилагаются образы виртуальных машин Xubuntu и Windows XP, а также ISO-образ с необходимым ПО.

Задание к практической работе

1. Настройка среды

Для выполнения работы потребуются три виртуальные машины, объединенных в общую сеть. В таблице 1 представлены параметры машин, на основе которых в VirtualBox можно настроить рабочую среду для данной лабораторной работы.

Таблица 1 – Параметры виртуальных машин

Название	ОС	Опер. память
Server	XUbuntu 64 бит	1,5 Гб
Client	Windows	512 Мб
Intruder	Windows или Kali Linux	512 Мб

Для объединения в общую сеть в меню File => Host Network Manager необходимо создать виртуальную сеть с настройками, представленными на рисунках 1 и 2.

The screenshot shows the 'Properties...' window for a virtual network. At the top, there are buttons for 'Create', 'Remove...', and 'Properties...'. Below is a table listing network adapters:

Name	IPv4 Address/Mask	IPv6 Address/Mask	DHCP Server
vboxnet0	192.168.33.1/24	fd00::1/64	☐ Enable
vboxnet1	10.0.9.1/24		☐ Enable

Below the table, there are tabs for 'Adapter' and 'DHCP Server'. The 'DHCP Server' tab is selected. It contains the following options:

- ☐ Configure Adapter Automatically
- ☒ Configure Adapter Manually

Under 'Configure Adapter Manually', there are input fields for:

- IPv4 Address: 10.0.9.1
- IPv4 Network Mask: 255.255.255.0
- IPv6 Address: (empty)
- IPv6 Prefix Length: 0

At the bottom, there are buttons for 'Reset', 'Apply', and 'Close'.

Рисунок 1 – Настройка виртуальной сети

The screenshot shows the 'DHCP Server' tab in the 'Properties...' window. It contains the following options:

- ☒ Enable Server

Below this, there are input fields for:

- Server Address: 10.0.9.1
- Server Mask: 255.255.255.0
- Lower Address Bound: 10.0.9.2
- Upper Address Bound: 10.0.9.254

Рисунок 2 – Настройка DHCP в виртуальной сети

Созданную сеть указать в настройках сетевых адаптеров машин (режим "Host Only Adapter"). Убедиться, что все MAC-адреса у машин различных (рисунок 3).

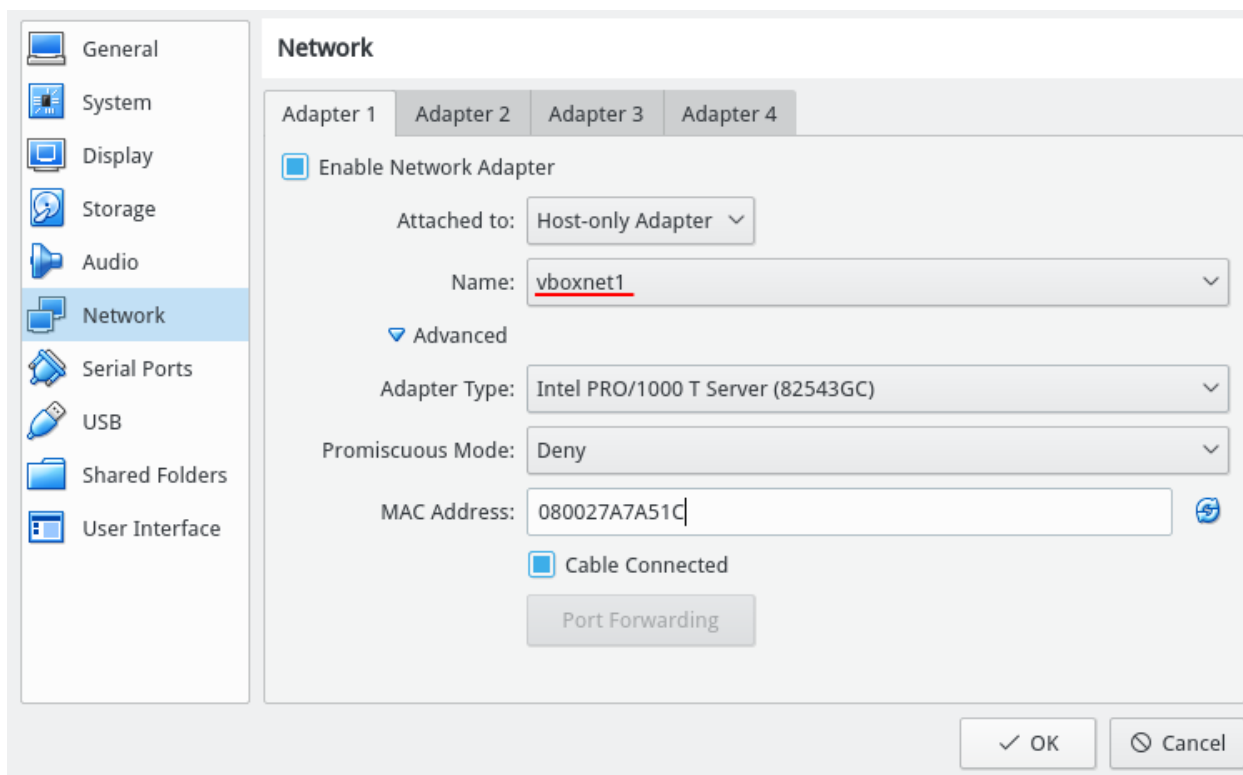


Рисунок 3 – Настройка сетевого адаптера виртуальных машин

Для работы потребуется также смонтировать во все виртуальные машины ISO-образ диска "IDS.iso" (рисунок 4).

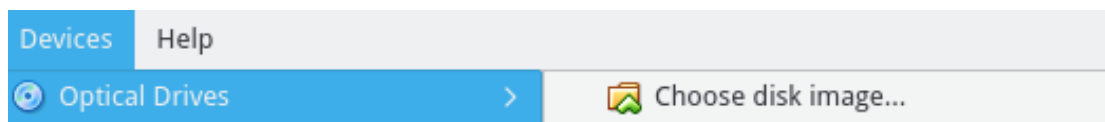


Рисунок 4 – Монтирование ISO-образа диска

В таблице 2 приведено рекомендуемое распределение IP-адресов, которое будет использоваться в работе. Чтобы получить такую конфигурацию адресов, необходимо производить первый запуск виртуальных машин в порядке возрастания последнего октета IP-адреса. После запуска машин требуется определить выданные им IP-адреса и записать эти сведения в отчет.

Убедитесь в видимости машинами друг друга с помощью утилиты ping. Стоит отметить, что 1-й IP адрес (10.0.9.1) выделен под хост-машину, которая также находится в общей сети.

Таблица 2 – Пример распределения IP-адресов

Роль виртуальной машины	IP-адрес
Хост-машина	10.0.<Номер учащегося>.1
Server	10.0.<Номер учащегося>.2
Client	10.0.<Номер учащегося>.3
Intruder	10.0.<Номер учащегося>.4

Сбросить неправильно назначенный адрес можно изменив MAC-адрес адаптера на случайно сгенерированный новый.

2. Настройка сервера

Откройте терминал и перейдите в директорию "packages" на прилагаемом к практической работе образе диска. Предварительно диск необходимо открыть нажатием на иконку на рабочем столе, чтобы определить папку, в которую он смонтирован. Запустите под администратором файл install-dependencies.sh для установки вспомогательного ПО и предварительной настройки виртуальной машины:

```
cd /media/student/IDS/packages
sudo ./install-dependencies.sh
```

Скрипт install-dependencies.sh также производит настройку веб-сервера Apache, который будет использоваться в дальнейшем для проверки работы IDS.

Ход работы скрипта продемонстрирован на рисунке 5.

После выполнения скрипта проверьте доступность этого сервера по адресу <http://10.0.9.2/>. Это можно сделать, например, из браузера на хост-машине.

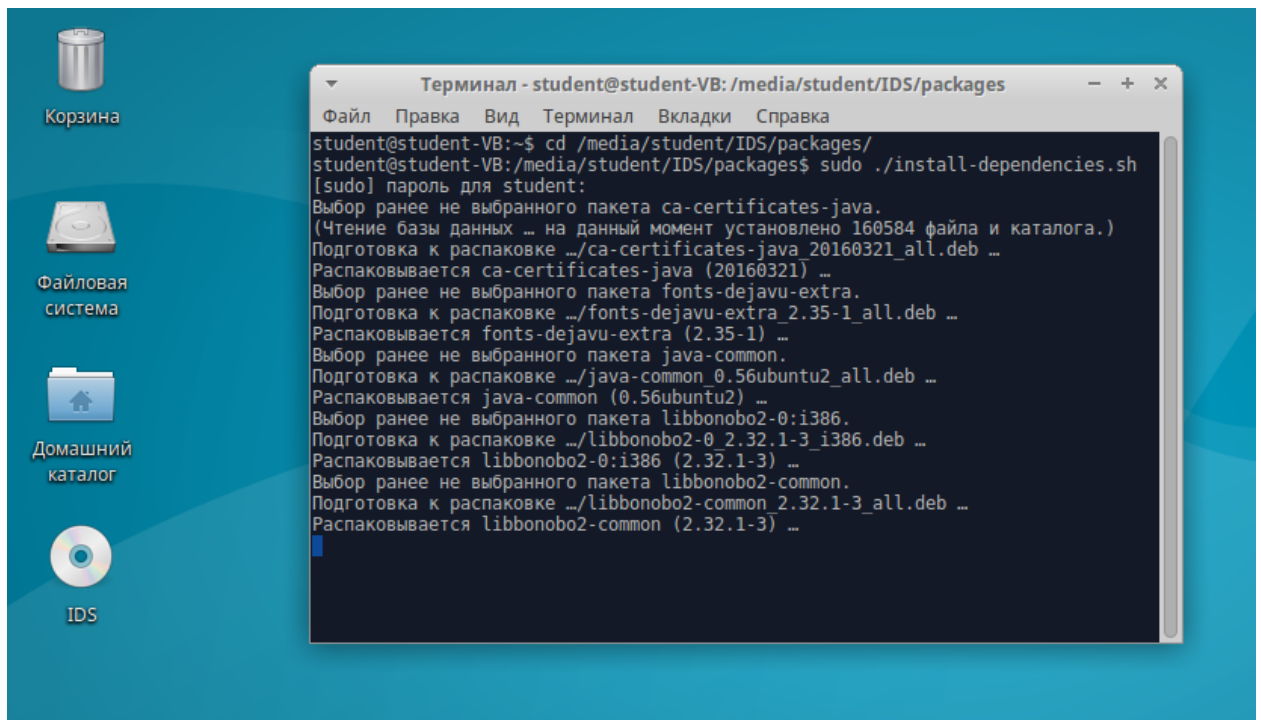


Рисунок 5 – Предварительная настройка сервера

Для установки IDS Suricata будет использоваться пакетный менеджер ОС Debian. На диске также находится архив с дополнительными правилами Emerging Threats, который необходимо распаковать утилитой *tar*. Таким образом, для установки Suricata необходимо выполнить:

```
sudo dpkg -i suricata_4.0.5-0ubuntu13_i386.deb  
sudo tar -xzf emerging.rules.tar.gz -C /etc/suricata/
```

Далее необходимо скопировать файл с конфигурацией и изменить в нем сетевой интерфейс, который будет прослушиваться. Это можно сделать с помощью утилиты *sed*, которая позволяет обработать и произвести замену. В данном случае слово "eth0" заменяется на "enp0s3". Убедитесь с помощью команды *ip link*, что в виртуальной машине действительно присутствует интерфейс enp0s3. Если он имеет другое название, подкорректируйте команду.

```
sudo cp -v /media/student/IDS/suricata.yaml /etc/suricata/suricata.yaml  
sudo sed -i -e 's/eth0/enp0s3/g' /etc/suricata/suricata.yaml
```

На этом установка и настройка Suricata закончена.

Аналогичным образом установим OSSEC:

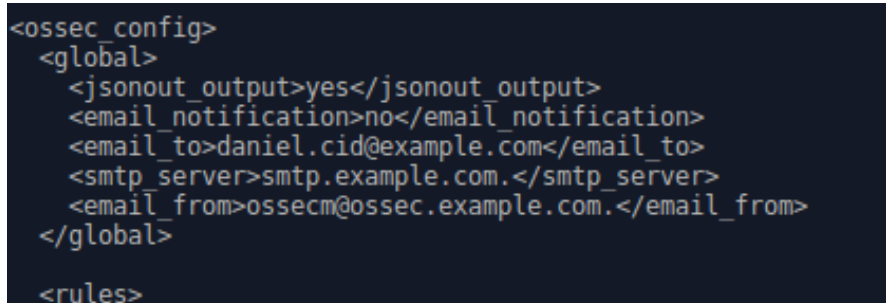
```
sudo dpkg -i ossec-hids-server_2.9.4-5512xenial_i386.deb
```

Для изменения настроек теперь будем использовать редактор *nano*:

```
sudo nano /var/ossec/etc/ossec.conf
```

В теле тега `<global>` необходимо добавить строчку для включения вывода отчетности в формате JSON, который затем будет анализироваться системой аналитики (рисунок 6).

```
<jsonout_output>yes</jsonout_output>
```



```
<ossec_config>
  <global>
    <jsonout_output>yes</jsonout_output>
    <email_notification>no</email_notification>
    <email_to>daniel.cid@example.com</email_to>
    <smtp_server>smtp.example.com.</smtp_server>
    <email_from>ossecm@ossec.example.com.</email_from>
  </global>

  <rules>
```

Рисунок 6 – Изменения в конфигурации OSSEC

Также необходимо отредактировать в конце настроек пути к лог-файлам сервера Apache, они должны указывать на файлы `/var/log/apache2/access.log` и `/var/log/apache2/error.log`. Внешний вид указанных частей файла приведен на рисунке 7.

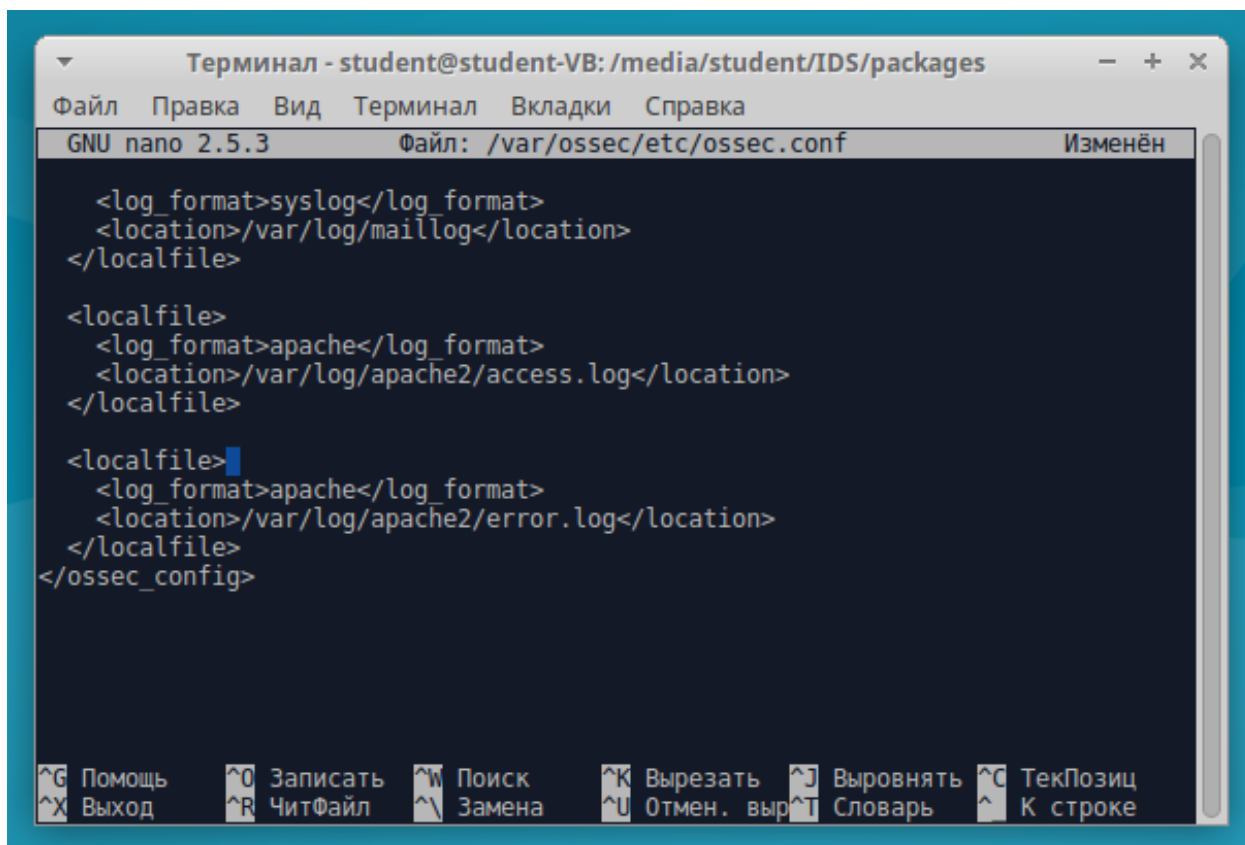


Рисунок 7 – Настройка путей к логам в OSSEC

Выполните следующую команду для копирования ключей агентов. Об этом будет рассказано позднее.

```
sudo cp -v /var/ossec/etc/client.keys /etc/client.keys
```

Установка и настройка OSSEC закончена. Следующим шагом будет установка и настройка стека программ для сбора и отображения аналитики. Перейдите в домашнюю директорию и выполните команды для распаковки архивов:

```
cd ~
tar -xvf /media/student/IDS/packages/elasticsearch-5.6.10.tar.gz
tar -xvf /media/student/IDS/packages/logstash-5.6.10.tar.gz
tar -xvf /media/student/IDS/packages/kibana-5.6.10-linux-x86.tar.gz
```


По умолчанию данные программы настроены на резервацию существенного объема оперативной памяти для своей работы (3 ГБ). Для тестовой среды такой объем не требуется, поэтому необходимо отредактировать два конфигурационных файла в домашней директории: `~/elasticsearch-5.6.10/config/jvm.options` и `~/logstash-5.6.10/config/jvm.options`. Отредактируйте эти файлы вручную, изменив объем памяти на 128MB и 64MB соответственно, либо выполните эти действия с помощью утилиты *sed*:

```
sed -i -e 's/Xms2g/Xms128M/g' -e 's/Xmx2g/Xmx128M/g' ~/elasticsearch-5.6.10/config/jvm.options
sed -i -e 's/Xms1g/Xms64M/g' -e 's/Xmx1g/Xmx64M/g' ~/logstash-5.6.10/config/jvm.options
```

Для Logstash скопируйте конфигурационный файл с диска, в котором настроено чтение логов Suricata и OSSEC:

```
cp -v /media/student/IDS/ids.conf ~/logstash-5.6.10/config/ids.conf
```

Чтобы веб-интерфейс был доступен из хост-системы, необходимо раскомментировать и изменить IP-адрес в файле `~/kibana-5.6.10-linux-x86/config/kibana.yml`:

```
server.host: "10.0.9.2"
```

Таким образом, настройка сервера закончена. **Обязательно** выполните перезапуск виртуальной машины для применения изменений в конфигурации. Затем запустите в отдельных консолях составляющие системы мониторинга:

```
cd ~/elasticsearch-5.6.10 && ./bin/elasticsearch
cd ~/logstash-5.6.10 && sudo ./bin/logstash -f config/ids.conf
cd ~/kibana-5.6.10-linux-x86 && ./bin/kibana
```

Как видно из листинга, Logstash будет запущен под администратором, так как этому процессу требуется доступ к лог-файлам. Параметр "-f" указывает путь к файлам с настройками. Дождитесь запуска всех составляющих и откройте страницу с мониторингом по адресу <http://10.0.9.2:5601/> (рисунок 8).

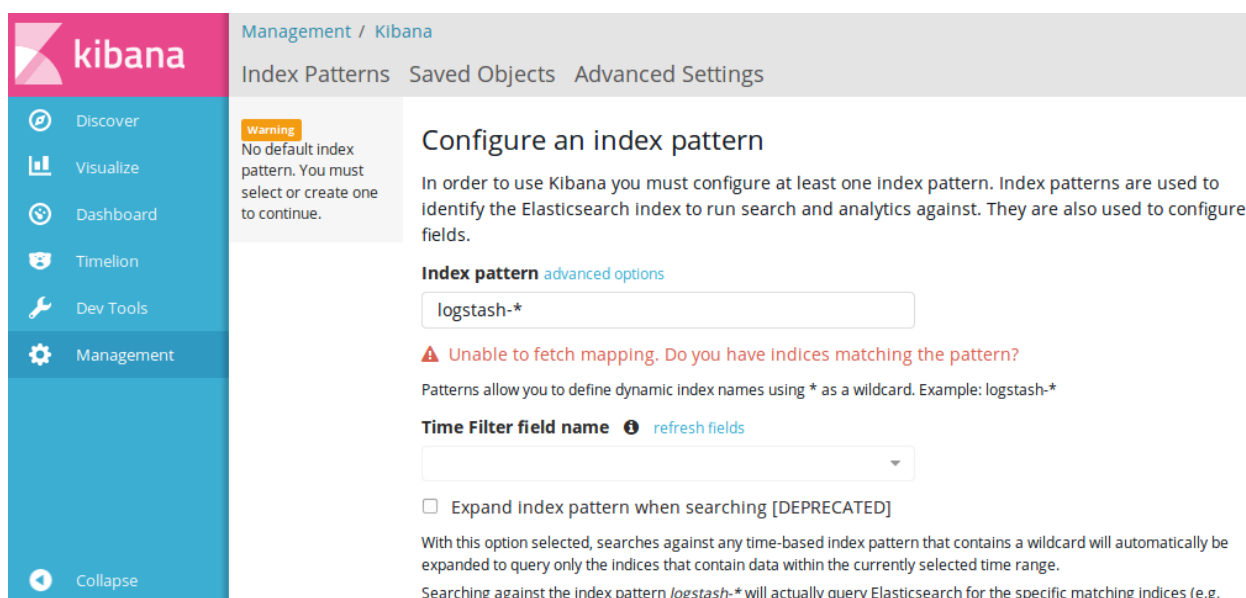


Рисунок 8 – Страница системы мониторинга после установки

3. Настройка системы мониторинга

Записи событий COB хранятся в таблицах NoSQL базы данных *Elasticsearch*. Информация в такой БД организована в так называемых «индексах» (index), напоминающих таблицы, где столбцы называются «поля» (field). В данной работе система сбора отчетов настроена так, что отчеты сохраняются в индексах вида "ossec-*" и "suricata-*", где вместо звездочки указывается дата. При первом открытии системы аналитики необходимо добавить два указанных шаблона, чтобы данные индексы были доступны в системе мониторинга (рисунок 9).

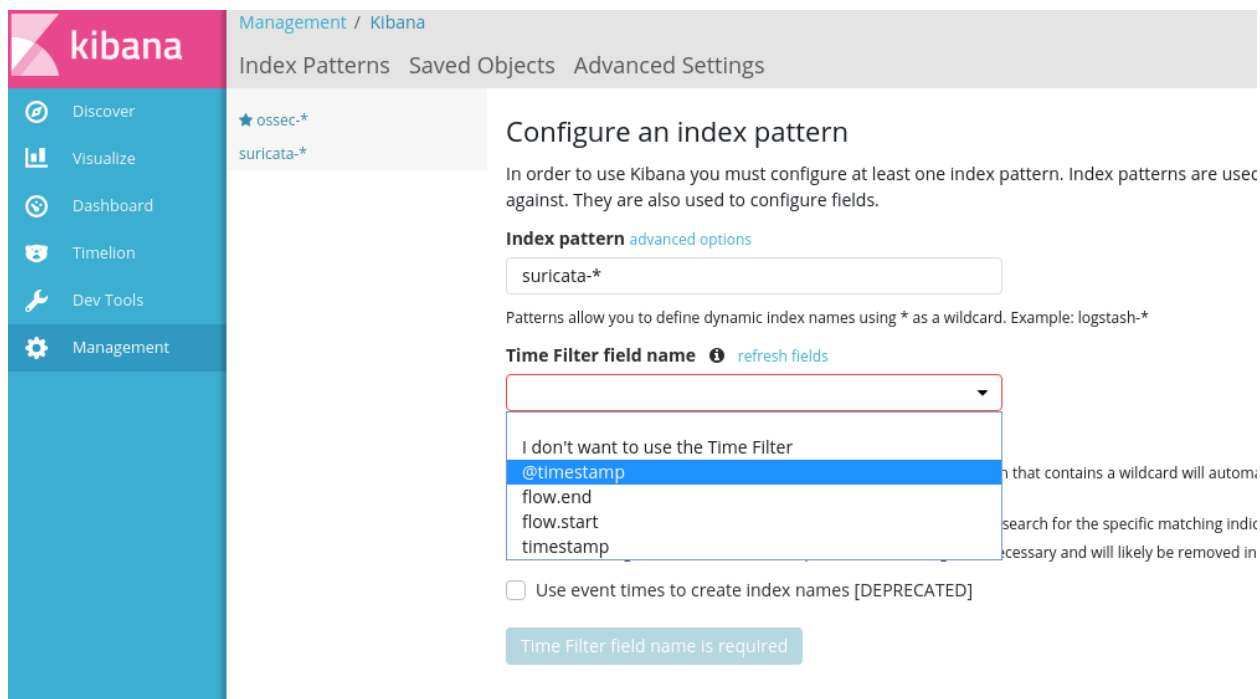


Рисунок 9 – Добавление шаблона для индексов

Теперь в разделе "Discover", настроив фильтры, можно наблюдать отчеты COB. Настройте отображение отчетов за соответствующий промежуток времени (в правом верхнем углу) и убедитесь в том, например, что OSSEC запущен (рисунок 10).

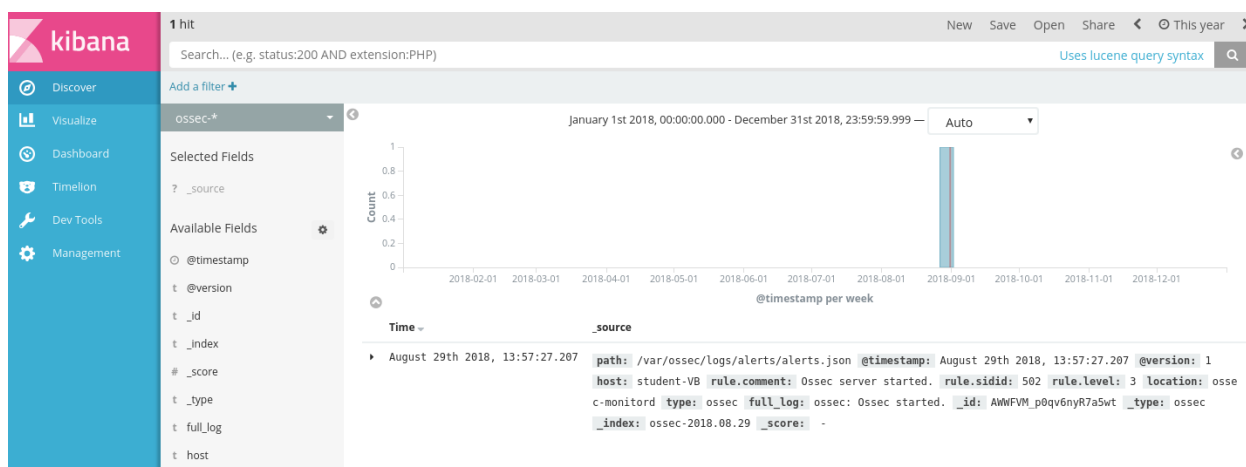


Рисунок 10 – Просмотр отчета OSSEC

Используя кнопки слева, можно настроить внешний вид списка. Для примера, проверим COB OSSEC. Перейдем на хост-системе на страницу <http://10.0.9.2/test-ids.html>. Эта страница содержит вывод команды `id`,

запущенной под администратором. COB настроена на обнаружение передачи подобной строки (так как она говорит о потенциально успешной атаке), поэтому в отчетности можно будет найти соответствующее сообщение (рисунок 11).

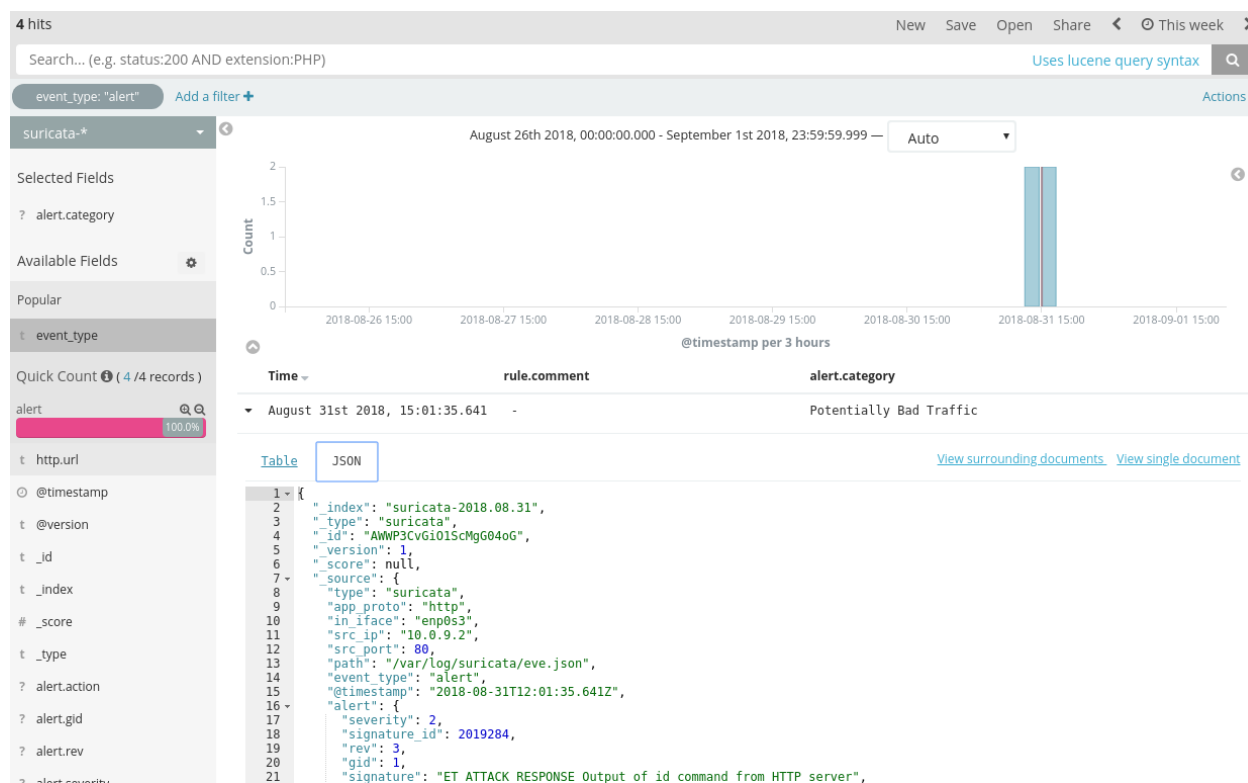


Рисунок 11 – Сообщение о потенциальной атаке через HTTP сервер

Система мониторинга обладает обширными возможностями визуализации аналитических данных. Создадим две визуализации, по которым можно будет оценить работу COB. Для этого на странице «Visualize» (в меню слева) создайте новую визуализацию типа «Pie» (круговая диаграмма). Для каждой COB необходимо выбрать свой индекс. Затем нажмите «Split Slices», выберите «Terms» (агрегация по словам) и выберите нужное поле в индексе. Для OSSEC это будет «rule.comment.keyword», для Suricata «alert.signature.keyword» (рисунок 12). Если указанных полей нет в списке возможных вариантов, то необходимо убедиться, что в БД присутствует хотя бы одна запись с таким полем (т.е. предыдущий шаг с проверкой COB должен быть выполнен) и что оно зарегистрировано как агрегируемое поле.

Последнего можно достичь, перейдя на страницу «Management» (в меню), выбрав индекс и нажав справа вверху кнопку для обновления полей. (рисунок 13)

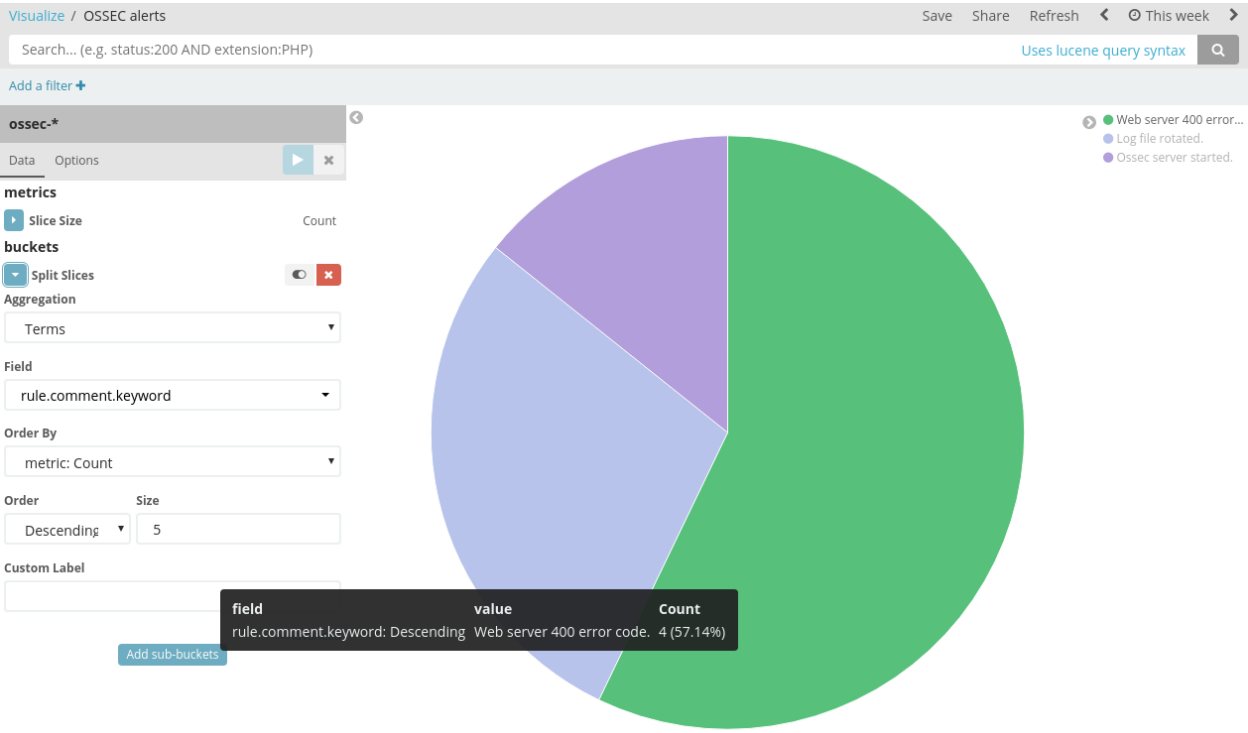


Рисунок 12 – Настройка визуализации (круговая диаграмма)

Management / Kibana

Index Patterns Saved Objects Advanced Settings

+ Create Index Pattern

ossec-*

suricata-*

Time Filter field name: @timestamp

This page lists every field in the **suricata-*** index and the field's associated core type as recorded by Elasticsearch. While this list allows you to view the core type of each field, changing field types must be done using Elasticsearch's [Mapping API](#)

fields (213) scripted fields (0) source filters (0)

Q Filter All field types

name	type	format	searchable	aggregatable	excluded	controls
@timestamp	date		✓	✓		
@version	string		✓			
@version.keyword	string		✓	✓		
_id	string		✓			
_index	string		✓	✓		
_score	number					
_source	_source					
_type	string		✓	✓		
alert.action	string		✓			
alert.action.keyword	string		✓	✓		
alert.category	string		✓			
alert.category.keyword	string		✓	✓		
alert.gid	number		✓	✓		

Рисунок 13 – Обновление полей индекса

Создайте Dashboard и добавьте туда две только что созданные визуализации (рисунок 14).

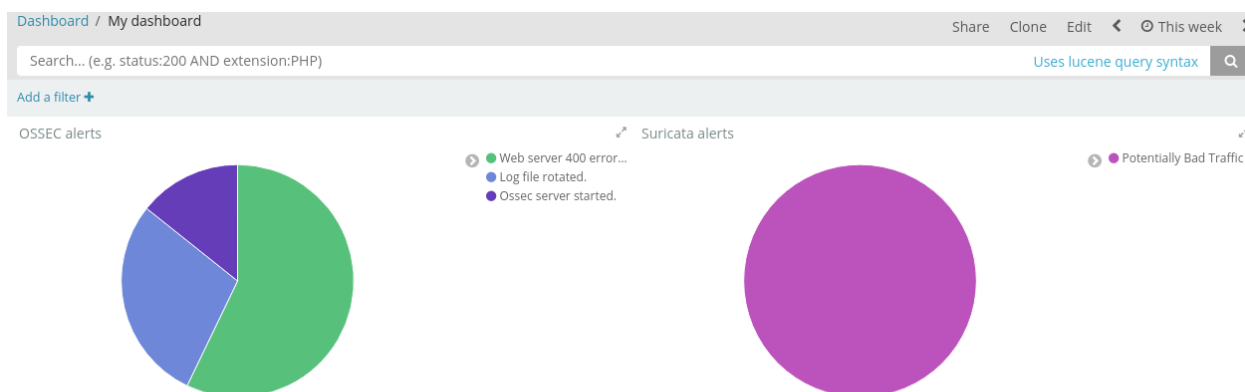


Рисунок 14 – Пример Dashboard

На этом настройка системы мониторинга завершена.

4. Проведение тестирования сервера на наличие уязвимостей

Запустите виртуальную машину Intruder. Смонтируйте прилагаемый к лабораторной работе образ диска и запустите установку сканеров NSTEALTH.EXE и NMAP_6_4.EXE. При установке вносить дополнительные изменения в конфигурацию не требуется.

Теперь запустите графический интерфейс Nmap - Zenmap и введите адрес сервера 10.0.9.2. Выберите тип сканирования "Quick Scan" и проведите сканирование портов сервера. Ожидаемый результат показан на рисунке 15.

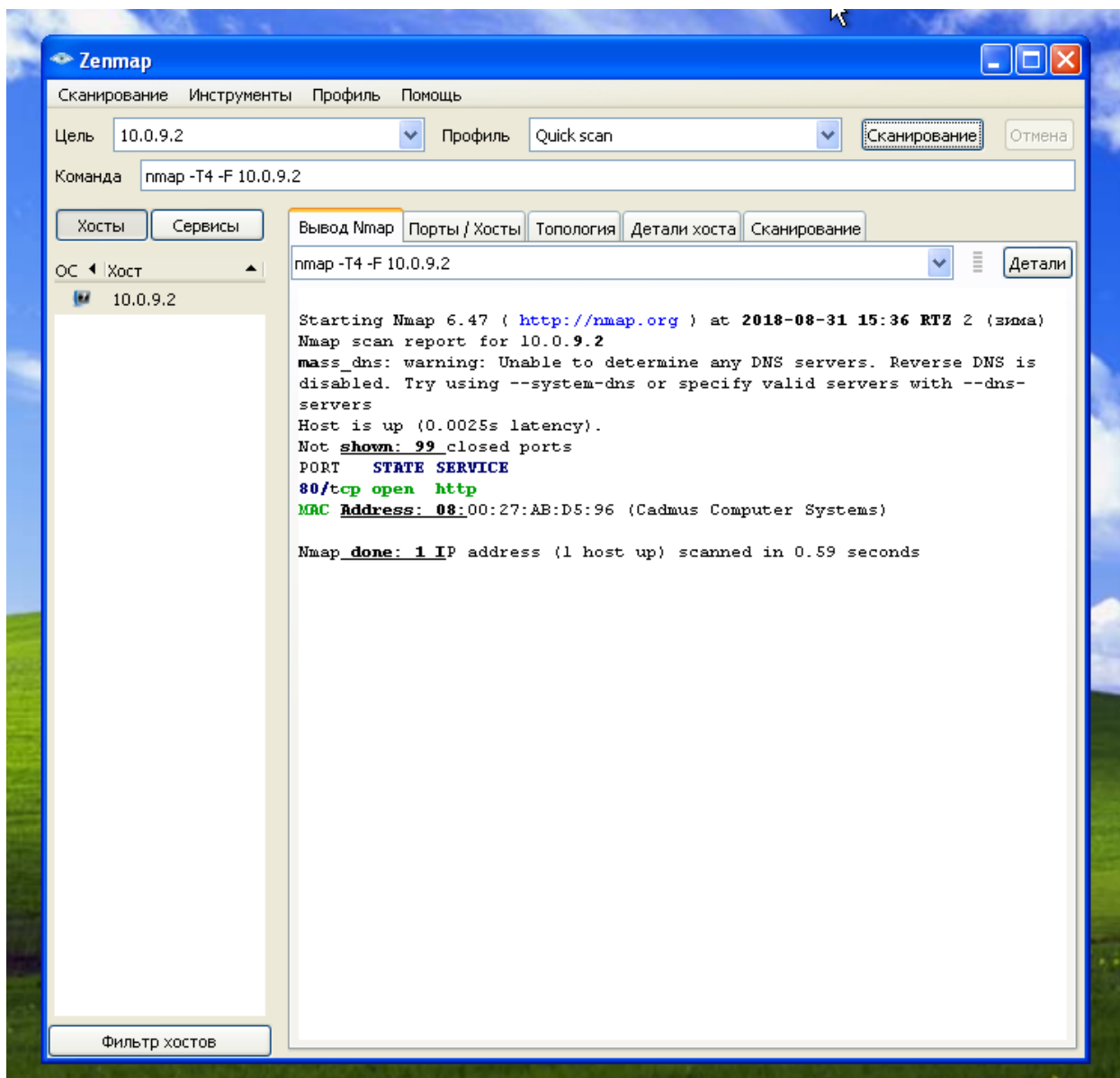


Рисунок 15 – Сканирование сервера с помощью Nmap

Убедитесь, что после проведения сканирования атакующим в системе аналитики через некоторое время (до минуты) появились записи о попытке сканирования (рисунок 16).

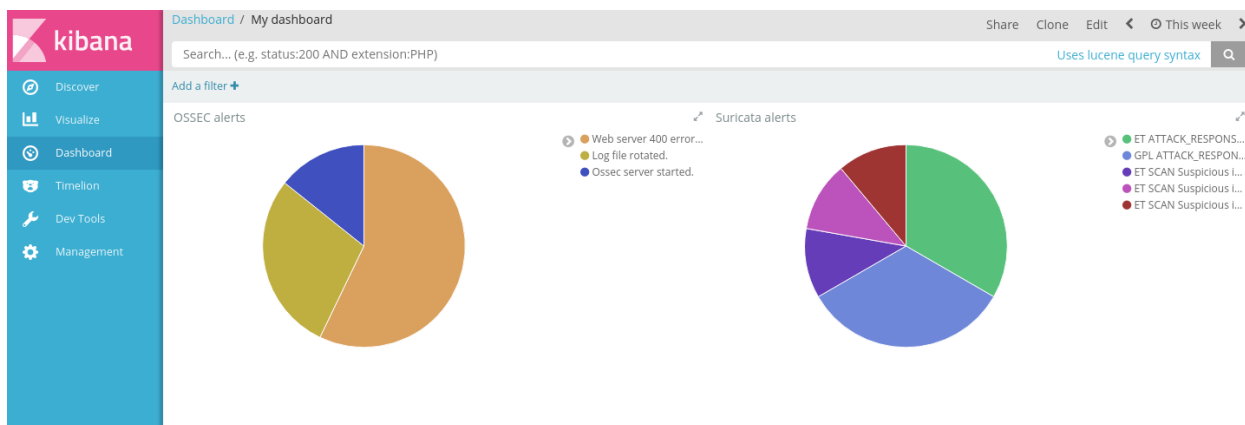


Рисунок 16 – Визуализация обнаруженного сканирования

Теперь запустите сканер NStealth, укажите адрес сервера 10.0.9.2, порт 80, метод сканирования «Standard scan» (рисунок 17). Запустите сканирование.

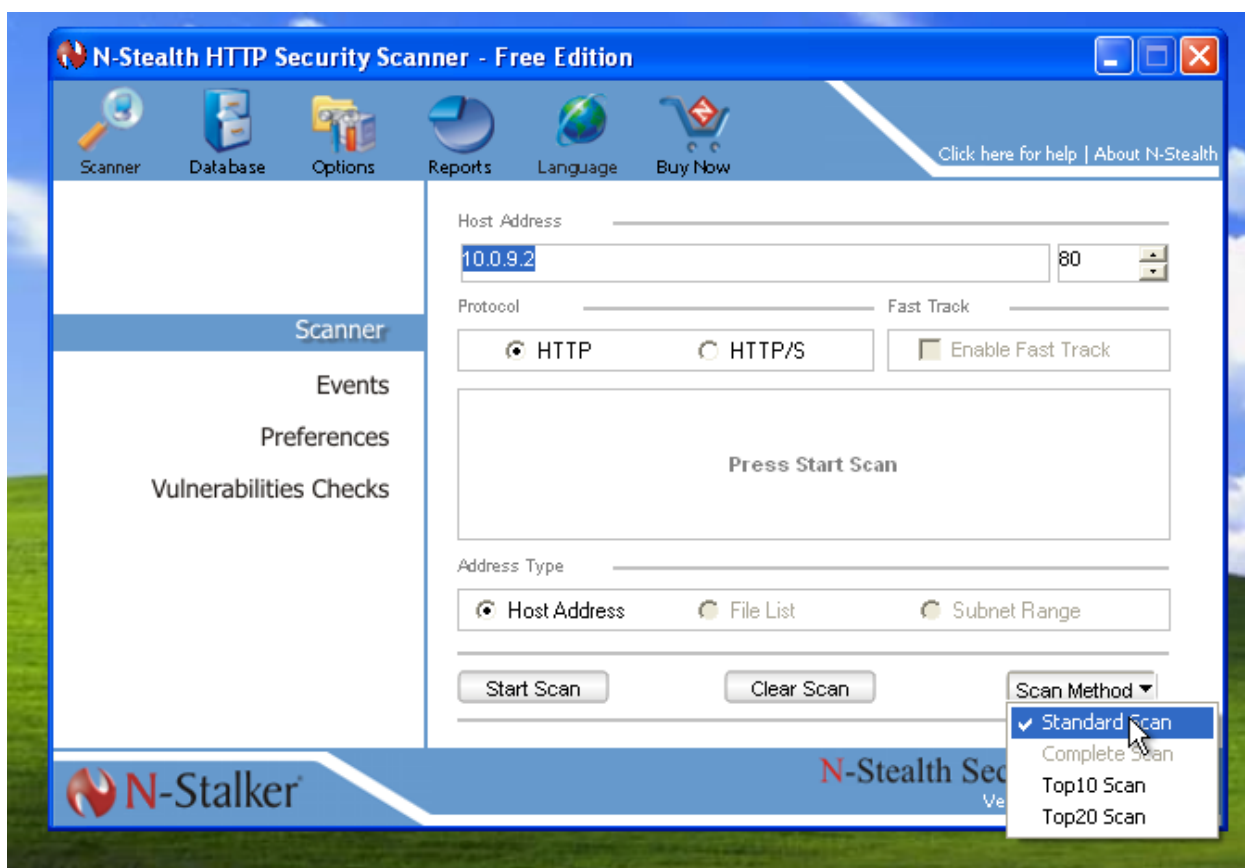


Рисунок 17 – Сканирование на уязвимости с помощью N-Stealth

После начала сканирования в системе аналитики появится информация об атаке (рисунок 18). При этом через некоторое время сканирование у злоумышленника должно прекратиться, так как OSSEC применит активный

метод защиты от атак - блокировка на некоторое время (10 минут) любой попытки подключения с IP-адреса злоумышленника к серверу. Убедитесь в недоступности сервера у злоумышленника, попытавшись открыть в Internet Explorer страничку сервера или выполнив *ping*.

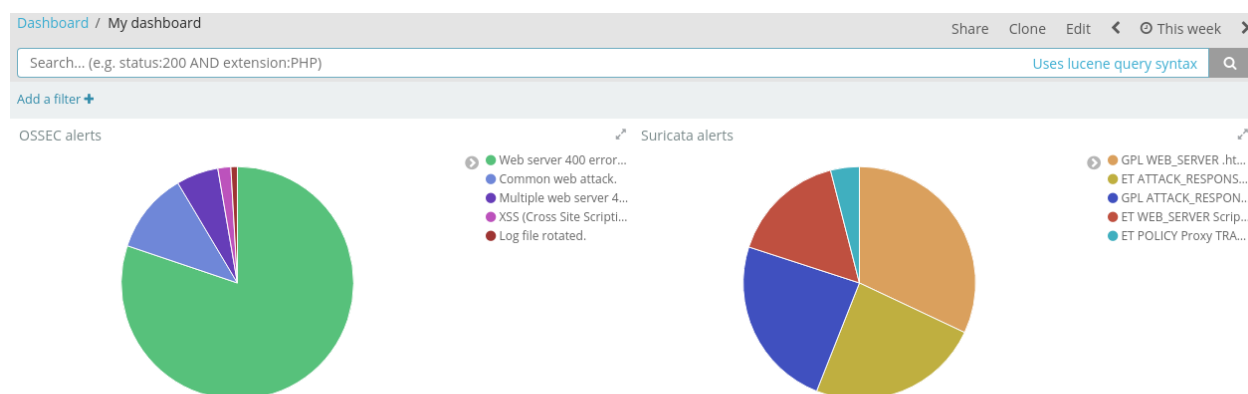


Рисунок 18 – Визуализация обнаруженной атаки

5. Настройка агента OSSEC на сервере клиента

Агент позволяет подключить к серверу другой ПК, на котором затем тоже будет проводиться сбор информации и обнаружение вторжений. В качестве такого ПК в данной работе выступает виртуальная машина "Client", на которой необходимо установить с образа диска агент (OSSEC_AG.EXE).

После установки агента необходимо на сервере зарегистрировать новую учетную запись. Выполните следующие команды:

```
sudo /var/ossec/bin/manage_agents
```

Нажмите A

Название агента: Client (можно любое)

IP адрес: 10.0.9.3

ID: оставить по умолчанию (001)

Далее необходимо передать клиенту ключ. На закрывая предыдущей программы, введите E, затем идентификатор (ID) агента из предыдущего шага (обычно 001). В консоль выведется ключ. Скопируйте его, выйдите из

программы (Q) и выполните команду ниже, чтобы опубликовать его на веб-сервере.

```
echo "<ВСТАВЬТЕ КЛЮЧ>" | sudo tee /var/www/html/key.html
```

Перед настройкой агента на клиенте создадим пустой файл C:\Windows\System32\wgareg.exe. Убедитесь, что файл имеет расширение .exe! После запуска агент произведет сканирование системы, обнаружит этот файл и выведет предупреждение о возможном заражении "Wargbot Backdoor".

Теперь откройте на клиенте Internet Explorer и перейдите по адресу <http://10.0.9.2/key.html>. Скопируйте ключ в буфер обмена, запустите агент и заполните адрес сервера и ключ (из буфера обмена). В полях не работает сочетание Ctrl+A, поэтому убедитесь, что Вы очистили их содержимое перед вставкой из буфера.

Нажмите "Save", затем Manage => Start OSSEC. После запуска нажмите "Refresh" (внешний вид агента представлен на рисунке 19). Через некоторое секунд в системе мониторинга появится сообщение о подключении нового агента, а затем (примерно через 5 минут) появится отчет, в котором будет содержаться информация о потенциально опасном файле (рисунок 20).

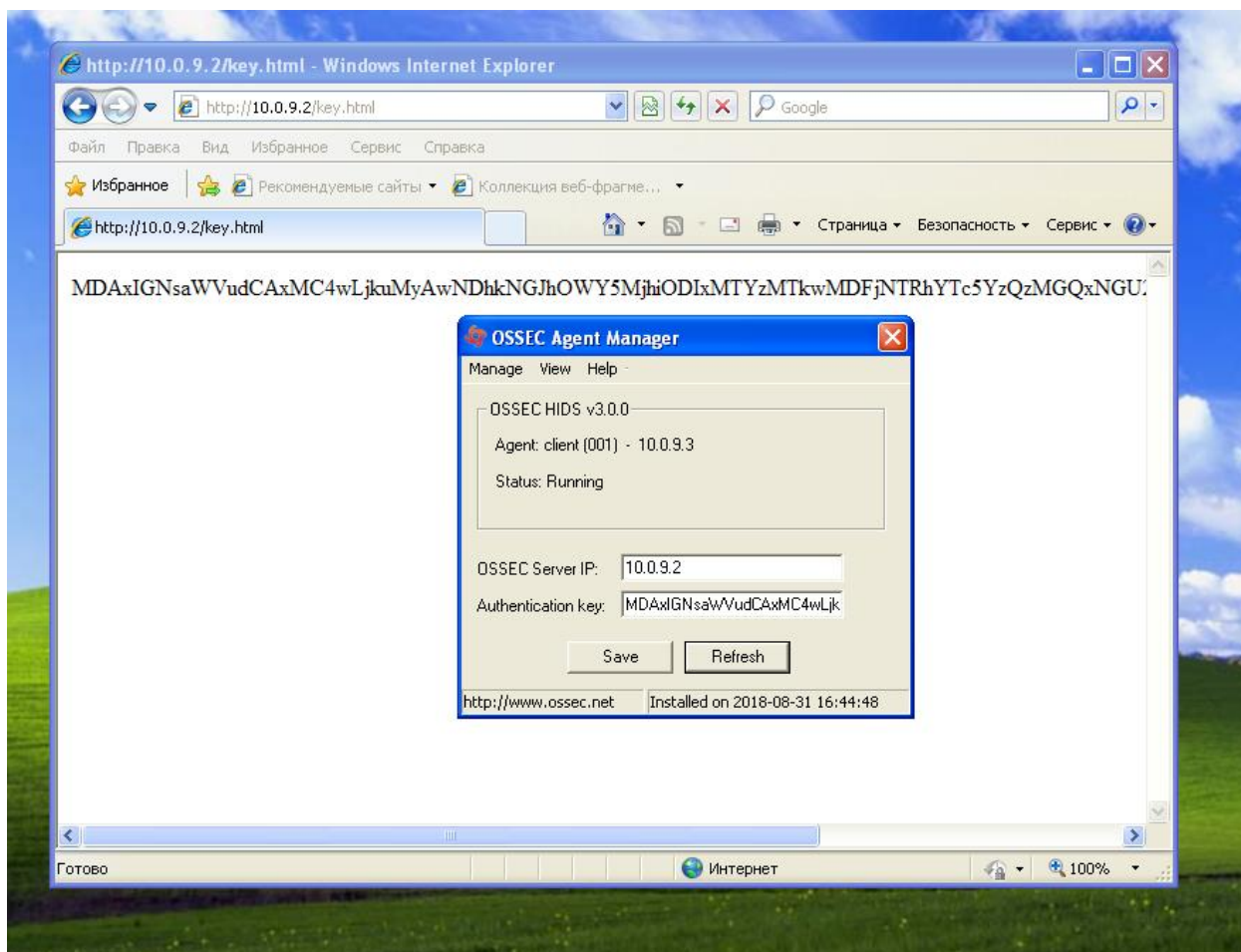


Рисунок 19 – Настройка агента OSSEC

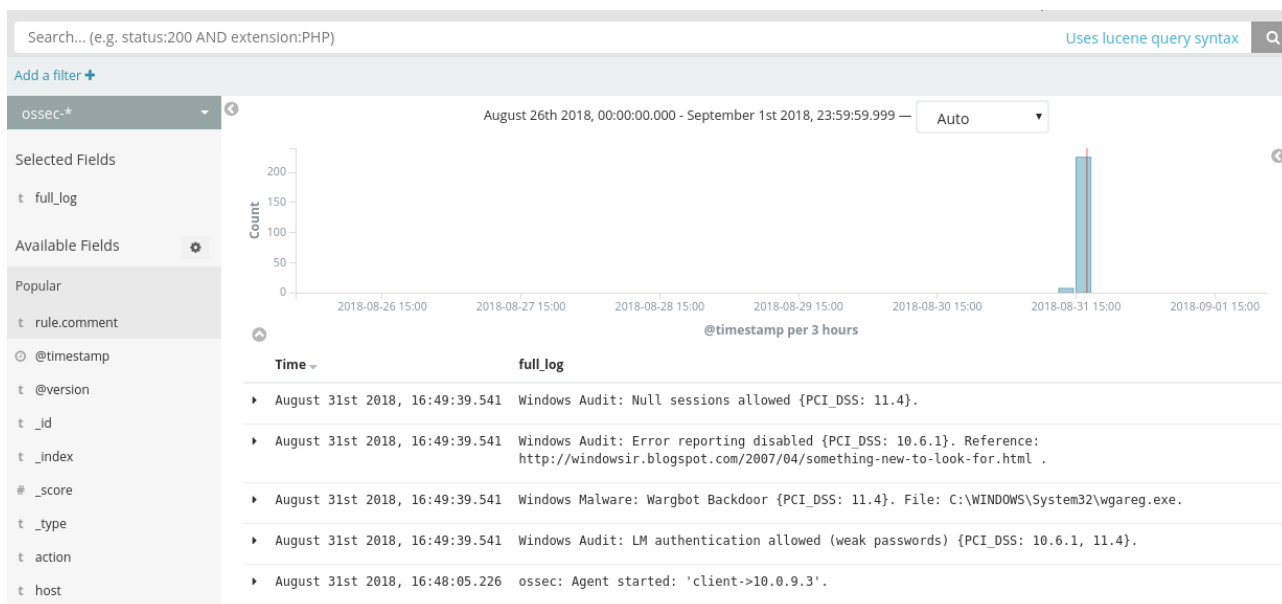


Рисунок 20 – Отчет о сканировании агента OSSEC

Сделайте вывод о возможной сфере применения, опишите преимущества и недостатки COB OSSEC и Suricata на основе

самостоятельного изучения отчетов в системе аналитики. Учтите, что COB Suricata не поддерживает агенты.

Составьте отчет о выполнении практической работы.

Включите в него копии экрана пошагового выполнения задания и ответы на вопросы практической работы.